

# CVE-2026-73570

## ZIMBRA SERVICE STATUS LOG SIGNALS

Validation of source-recommended service-status artifacts associated with actively exploited SNMP command injection.

VALIDATION QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

Syslog

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

22 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Sentinel · Syslog

ATT&CK

T1190

Evidence-led dossier. Query status remains an untested implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER



# EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

**Validate the reported log artifact without calling every service transition an exploit.**

Zimbra confirms command injection in the optional SNMP monitoring component before 10.1.20, while NVD describes crafted SMTP requests executing commands as the zimbra user. CISA added the flaw to KEV on 21 August. Reported CERT Polska guidance identifies suspicious Service status change records in /var/log/zimbra.log; the query retrieves those forms only when they are forwarded into Sentinel.

OPERATIONAL VALUE

**Immediate scoping value with a deliberately narrow claim.**

The validation surfaces raw service-state messages for incident review and confirms whether the required application log reaches the documented Syslog schema. It uses no arbitrary threshold, rarity score, payload inference or automatic CVE attribution.

9.3

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Validation

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

**Observed behavior**

- Zimbra 10.1.20 fixes command injection when SNMP notifications are enabled.
- NVD states that affected servers can execute operating-system commands as the zimbra user through crafted SMTP requests.
- CISA added CVE-2026-73570 to the Known Exploited Vulnerabilities catalog on 21 August 2026.

ANALYTICAL ASSESSMENT

**What the evidence supports**

- Reported CERT guidance makes service-status transitions useful retrospective pivots.
- The raw text can contain attacker-controlled material before the state-change suffix, but this implementation does not parse it.
- Legitimate restarts create the same state-transition suffixes, so the signal is validation evidence rather than an exploit verdict.

DETECTION ASSUMPTIONS

**What must be validated**

- Zimbra log records are routed through rsyslog or syslog-ng into AMA.
- The DCR retains the applicable facility and severity.
- SyslogMessage preserves the complete Zimbra record without truncation.

**Confidence boundary**

The CERT Polska page was unavailable during this review; the exact log guidance was corroborated through multiple independent reports. A match does not prove command execution, exploitation, vulnerability exposure or attacker identity.



# THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

## ATTACK FLOW

**01**

### Reach exposed SMTP

An unauthenticated actor sends a crafted SMTP request to a vulnerable deployment.

**02**

### Reach SNMP monitor

The optional zimbra-snmpp component is installed and notifications are enabled.

**03**

### Inject command

Unsanitized data reaches an operating-system command context.

**04**

### Execute as zimbra

The vulnerable path may execute commands under the zimbra service account.

**05**

### Create host evidence

Service transitions or attacker-created files may remain for incident review.

#### Observable core

A forwarded Zimbra log record containing Service status change plus one of the two reported running/stopped transition suffixes, with host, time and raw message retained.

#### Non-observable boundary

The SMTP payload, exact injected command, exit status, vulnerable configuration, successful exploitation, file creation and follow-on activity.

#### DETECTION HYPOTHESIS

### The reported service-state artifact should survive centralized log forwarding.

If exploitation or related command activity produces the reported Zimbra service-status records, Microsoft Sentinel should retain the complete text in SyslogMessage. Legitimate activity may be separated only by raw-message inspection, maintenance context, service ownership and adjacent host evidence.

#### REQUIRED TELEMETRY

##### Syslog

- /var/log/zimbra.log forwarded into the Syslog table.
- SyslogMessage and event timestamps.
- Origin host identity.

#### OPTIONAL ENRICHMENT

##### Context that improves disposition

- Zimbra version, package and SNMP-notification configuration.
- Maintenance and service-management records.
- Linux process, file, audit and authentication telemetry.

#### UNAVAILABLE HERE

##### Do not infer

- SMTP request body from Syslog.
- Command execution result.
- File creation by the zimbra account without host telemetry.



# TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Sentinel · Syslog

Microsoft documents SyslogMessage, event and ingestion timestamps, origin host, process, facility, severity, collector and resource fields in the Azure Monitor Syslog table.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

The table can preserve the raw application message if an environment-specific forwarding path exists. It does not automatically tail /var/log/zimbra.log or establish exploit semantics.

REQUIRED AND ENRICHMENT FIELD MODEL

| CATEGORY  | FIELD                                        | PURPOSE                                            | REQUIREMENT |
|-----------|----------------------------------------------|----------------------------------------------------|-------------|
| Log event | Syslog                                       | Primary raw-message record.                        | REQUIRED    |
| Message   | SyslogMessage                                | Reported status-change strings and analyst review. | REQUIRED    |
| Time      | TimeGenerated, EventTime                     | Ingestion and source-event timing.                 | REQUIRED    |
| Origin    | Computer, HostName, HostIP                   | Affected-server pivot.                             | REQUIRED    |
| Process   | ProcessName, ProcessID                       | Producer context when present.                     | OPTIONAL    |
| Routing   | Facility, SeverityLevel                      | DCR and parser verification.                       | REQUIRED    |
| Collector | CollectorHostName, SourceSystem, _ResourceId | Collection-path evidence.                          | OPTIONAL    |

Data quality requirements

- Confirm the Zimbra log file reaches rsyslog or syslog-ng.
- Verify the AMA DCR retains the relevant facility and severity.
- Generate a controlled service transition and preserve the raw event.
- Compare EventTime with TimeGenerated when a forwarder is used.

Known failure conditions

- /var/log/zimbra.log is not forwarded into Syslog.
- The DCR filters the relevant messages.
- The raw message is truncated or rewritten.
- The actor avoids the reported artifact or clears the log.



# DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

VALIDATION QUERY

DETECTION OBJECTIVE

**Retrieve the two reported Zimbra service-transition forms.**

Collect complete raw events for telemetry confirmation, benign-overlap measurement and incident scoping.

ANALYTICAL LOGIC

**Direct filters and investigable output.**

Three literal message predicates and investigable output. No parse, join, sequence, count, rarity, IOC list or malicious verdict.

KQL · UNTESTED VALIDATION

```
// Validation query - Untested implementation sketch
// Primary platform: Microsoft Sentinel / Log Analytics
// Required telemetry: /var/log/zimbra.log records forwarded as RFC 3164/5424
// Syslog through Azure Monitor Agent (AMA) and an applicable DCR.
// Evidence boundary: reported CERT Polska guidance recommends reviewing
// suspicious Zimbra "Service status change" records around active exploitation.
// A match does not prove CVE-2026-73570 exploitation or command execution.
Syslog
| where SyslogMessage contains "Service status change"
| where SyslogMessage contains "changed from stopped to running"
  or SyslogMessage contains "changed from running to stopped"
| project
  TimeGenerated, EventTime, Computer, HostName, HostIP,
  ProcessName, ProcessID, Facility, SeverityLevel,
  SyslogMessage, CollectorHostName, SourceSystem, _ResourceId
| order by TimeGenerated desc
```

| STATUS              | THRESHOLD | JOIN / SEQUENCE | PRIMARY KEY                                | DISPOSITION   |
|---------------------|-----------|-----------------|--------------------------------------------|---------------|
| Untested validation | None      | None            | HostName +<br>EventTime +<br>SyslogMessage | Manual triage |

**What a match means**

A reported Zimbra service-state log form is retained and must be reviewed against maintenance, configuration and host evidence.

**What a match does not prove**

CVE exploitation, injected command content, command success, persistence, web-shell creation or attacker attribution.



# TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

**Preserve the raw record.**  
Capture both timestamps, host, process, routing fields and complete SyslogMessage.
- 02

**Confirm exposure.**  
Verify Zimbra version, zimbra-snmp installation and notification configuration.
- 03

**Establish legitimacy.**  
Review maintenance, patching, restart and monitoring activity at the event time.
- 04

**Inspect the host.**  
Review files owned by zimbra in web roots and /tmp plus process and authentication evidence.
- 05

**Contain if corroborated.**  
Isolate, preserve forensic data, patch to 10.1.20 or later and rotate affected secrets.

Escalation gate

Escalate when the server is vulnerable and exposed, the raw message contains unexplained text, or the event aligns with unauthorized zimbra-owned files, shell activity, suspicious authentication or network evidence.

Primary benign overlap

Patching, maintenance, monitoring recovery and normal service management can generate identical state transitions. Tune through owned maintenance context and corroborating host evidence; never globally allowlist the suffixes.

INVESTIGATION PIVOTS

**Host**  
Version, role, Internet exposure and ownership.

**Configuration**  
zimbra-snmp package and notification state.

**Raw message**  
Text preceding the transition suffix.

**Files**  
Recent zimbra-owned files in web roots and /tmp.

**Process**  
Shells and child activity under the zimbra account.

**Network**  
SMTP source and post-exploitation connections.

DISPOSITION CRITERIA

| OUTCOME          | MINIMUM EVIDENCE                                                                   | ACTION                      |
|------------------|------------------------------------------------------------------------------------|-----------------------------|
| BENIGN           | Approved, owned and repeatable activity.                                           | Document and tune narrowly. |
| SUSPICIOUS       | Unknown activity without corroborated malicious follow-on.                         | Deepen endpoint review.     |
| LIKELY MALICIOUS | Unauthorized match plus coherent file, process, network or control-plane evidence. | Escalate incident response. |



# FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

| SCENARIO            | WHY IT OVERLAPS                                                   | TUNING ACTION                                                       |
|---------------------|-------------------------------------------------------------------|---------------------------------------------------------------------|
| Planned maintenance | Services stop and start during upgrades or configuration changes. | Require an owned change record and matching maintenance window.     |
| Monitoring recovery | SNMP or service supervision can record legitimate state recovery. | Validate service owner, preceding message text and monitor history. |
| Operational restart | Administrators may restart failed components.                     | Correlate with account, shell, ticket and host-health evidence.     |

Baseline plan

- Run across retained Syslog history for Zimbra hosts.
- Review every match with service owners.
- Measure message completeness and legitimate transition volume.
- Do not introduce a count or rarity threshold.

Validation procedure

- Generate a harmless controlled service transition.
- Confirm the local and Sentinel messages are byte-for-byte equivalent where feasible.
- Verify all projected fields and collector timing behavior.
- Review recent matches with version, SNMP and maintenance context.

TEST CASES

| CASE                                            | EXPECTED RESULT                                            |
|-------------------------------------------------|------------------------------------------------------------|
| Controlled Zimbra service stop/start            | Expected two transition records if forwarding is complete. |
| Unrelated Syslog message                        | No match.                                                  |
| Service status text without either exact suffix | No match.                                                  |
| Log line present locally but absent in Sentinel | Failure: repair forwarding before detection design.        |

Hunting

Initial query

Candidate

Current status

Production

Measured precision

Optimized

Stable feedback

Success

Controlled transitions appear with complete raw text and stable host/time fields, enabling incident review and benign-overlap measurement.

Rejection

Legitimate transitions dominate and no durable content, ownership or host-evidence discriminator can be established.

Failure

Controlled local events produce no usable Syslog record or the evidence-bearing message is truncated.



# ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

| TECHNIQUE | NAME                              | COVERAGE STATEMENT                                                                                                                                                      |
|-----------|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| T1190     | Exploit Public-Facing Application | Contextual coverage of a public-facing SMTP command-injection path; the query validates a reported host-log artifact and does not directly observe the exploit request. |

**Detection coverage summary**

Moderate for the reported service-transition artifact when Zimbra logs are forwarded; absent for request content, silent execution, cleared logs and non-Syslog pipelines.

**Residual risk**

Attackers can avoid service transitions, remove evidence, create different artifacts or exploit before telemetry is enabled. Patch verification and host forensics remain mandatory.

ANALYST CONCLUSION

**High-priority validation, not a production exploit detector.**

Official vendor, NVD and CISA evidence establish severity and active exploitation. The log predicate is operationally useful but comes through secondary reporting of CERT guidance and depends on environment-specific forwarding, so Medium-confidence Validation is the defensible classification.

REFERENCES

- Zimbra, "Zimbra Security Advisories," fix in 10.1.20; accessed 22 August 2026. [https://wiki.zimbra.com/wiki/Zimbra\\_Security\\_Advisories](https://wiki.zimbra.com/wiki/Zimbra_Security_Advisories)
- NIST NVD, CVE-2026-73570; published 13 August and modified 22 August 2026. <https://nvd.nist.gov/vuln/detail/CVE-2026-73570>
- CISA, KEV addition, 21 August 2026. <https://www.cisa.gov/news-events/alerts/2026/08/21/cisa-adds-one-known-exploited-vulnerability-catalog>
- CERT Polska guidance, 21 August 2026; primary page unavailable during review, exact strings corroborated by independent reporting. <https://moje.cert.pl/komunikaty/2026/145/aktywnie-wykorzystywana-podatnosc-w-zimbra-collaboration-suite>
- Microsoft Learn, Syslog table and Syslog via AMA documentation; accessed 22 August 2026. <https://learn.microsoft.com/en-us/azure/azure-monitor/reference/tables/syslog>
- MITRE ATT&CK, T1190. <https://attack.mitre.org/techniques/T1190/>

DOCUMENT CONTROL

| VERSION | DATE           | STATUS     | OWNER                 |
|---------|----------------|------------|-----------------------|
| v1.0    | 22 August 2026 | Validation | Detection Engineering |

**Publication control**

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.